Cybersecurity Terms Glossary

Essential Definitions for IT Professionals

© Dan Mill Training

A

Access Control - Security measures that determine who can access specific resources and what actions they can perform.

Advanced Persistent Threat (APT) - Sophisticated, long-term cyberattack where attackers gain unauthorized access and remain undetected for extended periods.

Antivirus - Software designed to detect, prevent, and remove malicious software (malware) from computer systems.

Authentication - Process of verifying the identity of a user, device, or system before granting access to resources.

Authorization - Process of granting or denying specific permissions to authenticated users or systems.

B

Backdoor - Hidden method of bypassing normal authentication or security controls to gain unauthorized access to a system.

Backup - Copy of data stored separately from the original to enable recovery in case of data loss or system failure.

Botnet - Network of compromised computers (bots) controlled remotely by cybercriminals to perform malicious activities.

Brute Force Attack - Method of attempting to gain access by systematically trying all possible password combinations.

C

Certificate Authority (CA) - Trusted entity that issues digital certificates to verify the identity of organizations or individuals.

CISO (Chief Information Security Officer) - Executive responsible for an organization's information security strategy and implementation.

Cloud Security - Set of policies, technologies, and controls designed to protect cloud-based systems, data, and infrastructure.

Cryptography - Practice of securing information by transforming it into an unreadable format using mathematical algorithms.

Cybersecurity Framework - Structured approach to managing cybersecurity risks, such as NIST Cybersecurity Framework.

Cyberattack - Deliberate attempt to damage, disrupt, or gain unauthorized access to computer systems or networks.

D

DDoS (Distributed Denial of Service) - Attack that overwhelms a target system with traffic from multiple sources, making it unavailable to legitimate users.

Data Breach - Incident where sensitive, protected, or confidential data is accessed, disclosed, or stolen by unauthorized individuals.

Data Encryption - Process of converting readable data into coded format to prevent unauthorized access.

Data Loss Prevention (DLP) - Security strategy and tools designed to prevent unauthorized access, use, or transmission of sensitive data.

Digital Forensics - Investigation and analysis of digital evidence to determine what happened during a security incident.

E

Endpoint Security - Approach to protecting devices (endpoints) like computers, mobile devices, and servers from cyber threats.

Encryption - Process of converting plain text into cipher text using cryptographic algorithms to protect data confidentiality.

Exploit - Code or technique that takes advantage of a vulnerability to gain unauthorized access or cause damage.

F

Firewall - Network security system that monitors and controls incoming and outgoing network traffic based on predetermined security rules.

Forensics - Scientific method of collecting, analyzing, and presenting digital evidence for legal proceedings.

G

Governance - Framework of policies, procedures, and controls that guide cybersecurity decision-making and implementation.

H

Hacker - Individual who uses technical skills to gain unauthorized access to computer systems; can be malicious or ethical.

Hash Function - Cryptographic algorithm that produces a fixed-size string from input data, used for data integrity verification.

Honeypot - Decoy system designed to attract and trap attackers to study their methods and protect real systems.

I

Identity and Access Management (IAM) - Framework for managing digital identities and controlling access to organizational resources.

Incident Response - Structured approach to handling and managing security incidents to minimize damage and recovery time.

Intrusion Detection System (IDS) - Security tool that monitors network or system activities and alerts on suspicious behavior.

Intrusion Prevention System (IPS) - Security system that monitors network traffic and actively blocks detected threats.

ISO 27001 - International standard for information security management systems providing requirements for establishing security controls.

J

JavaScript Injection - Attack where malicious JavaScript code is inserted into web applications to steal data or perform unauthorized actions.

K

Keylogger - Malicious software or hardware that records keystrokes to capture sensitive information like passwords.

L

Least Privilege - Security principle where users are granted minimum access rights necessary to perform their job functions.

Logic Bomb - Malicious code designed to execute when specific conditions are met, often after a certain date or event.

M

Malware - Malicious software designed to damage, disrupt, or gain unauthorized access to computer systems.

Man-in-the-Middle (MITM) - Attack where an attacker intercepts and potentially alters communications between two parties.

Multi-Factor Authentication (MFA) - Security method requiring users to provide two or more verification factors to gain access.

N

Network Security - Practices and technologies designed to protect network infrastructure from unauthorized access and attacks.

NIST Framework - Cybersecurity framework developed by the National Institute of Standards and Technology providing guidelines for managing cybersecurity risks.

O

OAuth - Open standard for access delegation, commonly used for secure authorization between applications.

P

Patch Management - Process of identifying, acquiring, testing, and installing software updates to fix vulnerabilities and improve functionality.

Penetration Testing - Authorized simulated cyberattack on a system to evaluate security weaknesses and vulnerabilities.

Phishing - Social engineering attack using fraudulent communications to trick individuals into revealing sensitive information.

PKI (Public Key Infrastructure) - Framework for managing digital keys and certificates to enable secure communication.

Q

Quarantine - Isolation of potentially malicious files or systems to prevent spread of threats while allowing further analysis.

R

Ransomware - Malicious software that encrypts victim's data and demands payment for the decryption key.

Risk Assessment - Process of identifying, analyzing, and evaluating potential cybersecurity risks to an organization.

Rootkit - Malicious software designed to maintain persistent access to a system while hiding its presence.

S

SIEM (Security Information and Event Management) - Technology that aggregates and analyzes security data from across an organization's infrastructure.

SOC (Security Operations Center) - Centralized facility where security professionals monitor, detect, and respond to cybersecurity incidents.

Social Engineering - Psychological manipulation techniques used to trick people into divulging confidential information or performing actions.

Spear Phishing - Targeted phishing attack directed at specific individuals or organizations using personalized information.

SQL Injection - Attack technique that inserts malicious SQL code into application queries to access or manipulate database information.

SSL/TLS - Cryptographic protocols that provide secure communication over networks, commonly used in web browsers.

T

Threat Actor - Individual or group responsible for malicious cyber activities, including hackers, cybercriminals, and nation-states.

Threat Intelligence - Information about current and potential cybersecurity threats used to help organizations protect against attacks.

Two-Factor Authentication (2FA) - Security method requiring users to provide two different authentication factors to verify their identity.

Trojan Horse - Malicious software that disguises itself as legitimate software to gain unauthorized access to systems.

U

User Access Review - Regular examination of user permissions and access rights to ensure they remain appropriate and necessary.

V

Vulnerability - Weakness in a system, application, or network that could be exploited by threats to gain unauthorized access or cause damage.

Vulnerability Assessment - Systematic review of security weaknesses in an information system to determine potential exploits.

VPN (Virtual Private Network) - Secure connection that allows users to access private networks over public internet connections.

W

WAF (Web Application Firewall) - Security system that filters, monitors, and blocks HTTP traffic to and from web applications.

Whaling - Targeted phishing attack directed specifically at high-profile individuals like executives or senior officials.

White Hat Hacker - Ethical hacker who uses skills to help organizations improve their security by identifying vulnerabilities.

Worm - Self-replicating malware that spreads across networks without requiring user interaction.

X

XSS (Cross-Site Scripting) - Web application vulnerability that allows attackers to inject malicious scripts into websites viewed by other users.

Z

Zero-Day - Previously unknown software vulnerability that has not yet been patched by the vendor.

Zero Trust - Security model that requires verification of every user and device before granting access to systems or data.

Common Acronyms Quick Reference

Acronym	Full Term	Purpose
APT	Advanced Persistent Threat	Long-term targeted attacks
CA	Certificate Authority	Issues digital certificates
CISO	Chief Information Security Officer	Security leadership role
DDoS	Distributed Denial of Service	Network attack method
DLP	Data Loss Prevention	Protects sensitive data
IAM	Identity and Access Management	Manages user access
IDS	Intrusion Detection System	Detects suspicious activity
IPS	Intrusion Prevention System	Blocks detected threats
MFA	Multi-Factor Authentication	Enhanced login security
MITM	Man-in-the-Middle	Interception attack
PKI	Public Key Infrastructure	Digital key management
SIEM	Security Information and Event Management	Security monitoring
SOC	Security Operations Center	Security monitoring facility
VPN	Virtual Private Network	Secure remote access
WAF	Web Application Firewall	Web security protection
XSS	Cross-Site Scripting	Web vulnerability type

Security Frameworks and Standards

NIST Cybersecurity Framework - Voluntary framework for improving cybersecurity risk management

- **Identify** - Asset management and risk assessment
- **Protect** - Access controls and data security
- **Detect** - Continuous monitoring and detection
- **Respond** - Incident response and communication
- **Recover** - Recovery planning and improvements

ISO 27001 - International standard for information security management systems

COBIT - Framework for governance and management of enterprise IT

CIS Controls - Set of prioritized cybersecurity best practices

---

Remember: Cybersecurity terminology evolves rapidly with new threats and technologies. Stay updated with the latest definitions and industry standards to maintain effective security practices.

This document is part of the cybersecurity training materials by Dan Mill Training.